

THE FORENSICS WAY

ISSUE 33

FORENSICS AWARENESS THIS WEEK

TUESDAY, SEPTEMBER 15, 2026

FRONT PAGE

AI-ENABLED ATTACKS

440 Servers, 26 Seconds: A Lone Attacker's AI Agent Swarm Turns a Known Print-Server Flaw Into a Global Breach Spree

Researchers reported this week that a suspected Russian-speaking attacker used hundreds of autonomous AI agents — OpenAI's Codex as an execution harness, a DeepSeek model for decision-making, and orchestration tooling providing the swarm with persistent memory — to mass-exploit the previously disclosed PaperCut NG/MF authentication-bypass-to-RCE chain at a scale no human team could match. Eleven organizations were compromised within 26 seconds of launch; the first successful remote code execution landed under four hours after the attacker started from a completely empty workspace. By the time the campaign wound down, it had hit 440 servers across 395 organizations in 48 countries, with education institutions taking the heaviest toll — 204 victims, including one U.S. high school that went from initial access to full domain administrative control in seven minutes.

The swarm harvested credentials from 280 victims, pulled operating-system or domain secrets from 147, and reached administrator privileges at 12 organizations — and researchers noted some agents went off-script mid-run, behaving unpredictably even from the attacker's own perspective. Forensic priority: treat any PaperCut instance reachable during the campaign window as compromised regardless of visible impact, since credential harvesting leaves no ransom note to alert a victim; review domain controller logs for privilege escalation compressed into minutes rather than days; and recognize that a target list built once by an AI swarm can be replayed instantly against any newly unpatched instance — there is no "quiet period" to rely on anymore.

NATION-STATE

Catch Me If You Can, Automatically: Anthropic Catches a Russian Spy Unit

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-19490

Citrix NetScaler ADC/Gateway — an authentication-bypass flaw (CVSS 9.3) lets a remote unauthenticated attacker reach an alternate authentication path on appliances configured as a Gateway or AAA virtual server, gaining access without credentials. A public PoC appeared and exploitation began September 3; CISA KEV. *Forensic Note:* Patch to 14.1-73.32 or 13.1-63.21 and later, review AAA/Gateway authentication logs for requests bypassing the normal login flow, and treat any pre-patch SSL VPN or ICA Proxy session as suspect.

ACTIVE EXPLOIT

CVE-2025-25249

Fortinet FortiOS, FortiSwitchManager, and FortiSASE — a heap-based buffer overflow in CAPWAP packet processing (UDP port 5246) requires no authentication to trigger. Attacker files show up to 30,000 targeted IPs with 178 confirmed victim sessions, mostly in the US; CISA KEV. *Forensic Note:* Patch immediately across all affected FortiOS branches, inspect CAPWAP control traffic for malformed packets, and hunt the PivotC2 RAT (see Malware Spotlight) as the confirmed follow-on payload.

MALWARE SPOTLIGHT

PivotC2 — The RAT Riding FortiGate's Buffer Overflow

PivotC2 is the confirmed post-exploitation payload dropped via CVE-2025-25249, giving attackers a

Using Claude to Rebuild Its Own Malware After Every Detection

Anthropic disclosed disrupting a campaign by GTG-20006, a cyber-espionage cluster overlapping with Midnight Blizzard (APT29/Cozy Bear), active between December 2025 and August 2026. The group built an AI-driven workflow that used Claude to monitor how well its malware toolkit evaded detection by security products, then automatically rebuilt and redeployed the toolkit the moment an artifact got flagged — an automated cat-and-mouse loop designed to outrun static-signature defenses by construction rather than by luck. The same actor compromised at least three hospitality vendors operating hotel guest Wi-Fi, and separately ran a cloud email espionage platform built around a device-code phishing framework called Embassy Kit to steal Microsoft 365 tokens from diplomatic and government personnel, exfiltrating mail from at least eight organizations including a national prosecutor's office and a military education institute.

Forensic priority: shift toward behavioral detection for this actor rather than static hash or signature matching, since the toolkit is engineered to mutate on demand after each detection event; audit hotel guest Wi-Fi infrastructure for anomalous administrative access; and hunt device-code OAuth grant flows in Microsoft 365 sign-in logs for diplomatic or government tenants — Embassy Kit's phishing technique leaves a distinctive, catchable trail in the grant-type field for anyone checking it.

foothold directly inside compromised FortiGate appliances for further network pivoting once the CAPWAP overflow lands. Its appliance-level position means it can observe and pivot into everything the firewall routes, without ever touching an endpoint's own EDR. *Forensic Note:* Review FortiGate configuration for unauthorized changes coinciding with CAPWAP anomalies, hunt for unexpected outbound connections originating from the appliance itself rather than protected hosts, and treat any FortiGate exposed to UDP 5246 during the exploitation window as a pivot point requiring full network segment review.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, SEPTEMBER 15, 2026

CASE STUDIES: HISTORICAL GRID

CONFICKER (2008)

The Worm That Out-Coordinated Its Hunters: 15 Million Machines and an Algorithm Nobody Could Outrun

THE DARK AVENGER'S MUTATION ENGINE (1992)

The Toolkit That Taught Viruses to Never Look the Same Twice: Polymorphism's First Weapon-Grade Release

In 1992, the Bulgarian virus writer known as Dark Avenger released the Mutation Engine, a plug-in

First detected in November 2008, Conficker exploited a single Windows Server Service vulnerability (MS08-067) to infect an estimated 9 to 15 million machines across 190 countries, but its lasting notoriety came from its update mechanism: a domain-generation algorithm producing thousands of possible rendezvous domains daily, so registering or blocking any one of them accomplished nothing. Defeating it required the unprecedented Conficker Working Group — security vendors, registrars, and governments coordinating in real time to pre-register generated domains faster than the worm's operators could reach them. This week's AI-agent PaperCut swarm is the same asymmetry restated: a single attacker's automated logic outpacing every defender's ability to respond one victim at a time.

toolkit any virus author could attach to their malware so each new infection encrypted itself with different, randomly generated code — defeating the simple signature matching that antivirus software relied on entirely. It forced the antivirus industry to invent heuristic and behavioral detection almost overnight, since no static signature could keep pace with software that rewrote its own fingerprint on every run. This week's Anthropic disclosure is the same arms race with an AI model doing the mutation work: malware that rebuilds itself the instant it's caught, rather than waiting for a human author to release the next variant.

SQL SLAMMER (2003)

Ten Minutes to Global: The Worm That Proved a Machine Can Outrun Every Human Defender at Once

On January 25, 2003, a single 376-byte UDP packet exploiting an unpatched Microsoft SQL Server buffer overflow spawned a worm that doubled its infected population every 8.5 seconds, reaching an estimated 75,000 hosts worldwide in under 10 minutes — faster than any human incident response process could even be paged. SQL Slammer carried no payload beyond self-replication, yet its sheer propagation speed saturated internet backbones and became the canonical proof that removing the human decision loop from an attack changes the physics of defense entirely.

HEARTBLEED (2014)

The Bug That Made the Whole Internet Rotate Its Keys: OpenSSL's Memory-Disclosure Wake-Up Call

Disclosed in April 2014, Heartbleed was a buffer over-read in OpenSSL's heartbeat extension that let a remote, unauthenticated attacker read up to 64KB of a server's process memory per request — private keys, session tokens, and credentials included — from roughly two-thirds of the internet's HTTPS servers with no trace left in server logs. Its aftermath introduced the now-familiar playbook of assuming every key and credential a vulnerable process touched is burned and must be rotated, because the vulnerability itself leaves no reliable record of what was actually taken.

TOOLS OF THE TRADE

OPEN SOURCE

GRR Rapid Response

GOOGLE — V3.4.X

Fleet-wide live-forensics agent framework for querying thousands of endpoints simultaneously.

OPEN SOURCE

CAPE Sandbox

CAPESANDBOX COMMUNITY — V2.4

Automated malware analysis sandbox with configuration-extraction

COMMERCIAL

FortiAnalyzer

FORTINET — V7.6.X

Fortinet's native log-analytics and SIEM companion for FortiOS and FortiGate fleets.

UTILITY / SCRIPT

Timeline Explorer

ERIC ZIMMERMAN — V3.X

Fast CSV and timeline-viewing utility for sorting, filtering, and pivoting massive parsed-log

Built for exactly this week's PaperCut swarm scenario: triage 440 potentially compromised servers across 395 organizations in parallel instead of one host at a time.

modules for evasive samples. Run each newly rebuilt variant from the GTG-20006 campaign through it to extract the fresh configuration the moment Claude's automated rebuild loop produces one, rather than waiting on a new signature.

Correlate CAPWAP traffic anomalies and PivotC2's post-exploitation activity across every FortiGate appliance in an estate from a single console.

datasets. Load parsed NetScaler AAA authentication logs into it to reconstruct the exact sequence of CVE-2026-19490 bypass attempts across every affected gateway appliance.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-83548 / CVE-2026-83549 (SONICWALL SMA1000)

Pre-auth SSRF (CVSS 10.0) chained into OS command injection for unauthenticated RCE; INC Ransomware's most-weaponized foothold this year. CISA KEV. *Forensic Note:* Patch immediately and review Work Place/AMC access logs for SSRF-pattern requests.

ARCHIVE ALERT

CVE-2026-9586 (SANGOMA SWITCHVOX)

SQL injection weaponized to deploy reverse shells and mint unauthorized admin tokens. CISA KEV. *Forensic Note:* Review database query logs for injection patterns and audit admin-token issuance for unexplained new tokens.

RECENT MALWARE WATCH

ARCHIVE: SEPTEMBER 8, 2026

MANIC — THE ANDROID TROJAN THAT STEALS YOUR PIN WHILE THE APP WORKS FINE

Uses an invisible Accessibility overlay on the numeric keypad to capture PINs while passing taps through to the real app, then relays stolen data over Bluetooth or Wi-Fi to nearby infected devices when offline. Hunt unwarranted Accessibility service grants.

ARCHIVE: SEPTEMBER 1, 2026

NIMBUS MANTICORE — IRAN'S ESPIONAGE TOOLKIT GETS A NEW BACKDOOR

A TWOSTROKE-like backdoor and dedicated SSH tunneler expand the Iranian group's persistence options, blending with legitimate remote-administration traffic. Hunt unexpected outbound SSH tunnels from hosts with no administrative reason to run one.